Module 02: Reconnaissance

Search Engines for Reconnaissance

Project Athena

Search Engines as Recon Tools

Fully passive

You query Google or Shodan. The target never sees a packet.

- Google indexes pages, including ones nobody meant to publish
- Shodan indexes devices

Google Dorking

The Operators

```
site:example.com
filetype:pdf      ext:xls
inurl:admin       intitle:"index of"
intext:confidential
```

What People Leave Lying Around

```
intitle:"index of" backup
site:example.com ext:sql
intitle:"phpinfo()"
```

- Directory listings, database dumps
- Config files with credentials
- Exact software versions



Google Hacking Database

Curated dorks, by category: exploit-db.com/google-hacking-database

- Login pages, vulnerable servers
- Files containing passwords
- Error messages that leak paths

Shodan

What is Shodan?

> The search engine for everything connected to the internet.

- Scans the whole IPv4 space, grabs banners, indexes them
- Webcams, routers, databases, ICS, medical devices
- Cross-references versions with CVEs

Shodan Filters

```
hostname:example.com
org:"Example Corp"
port:3389  country:AT
product:"Apache" version:"2.4.49"
vuln:CVE-2021-44228
```

What Shodan Shows About You

- `org:` lists every IP registered to you
- Only 443 open? Good.
- `vuln:` has results? Patch today.



Shodan CLI

```
pip install shodan
shodan init YOUR_API_KEY
shodan search 'org:"Example Corp"'
shodan host 203.0.113.10
```


DATABASE ON PORT 27017, NO AUTH
THIS IS FINE
Memegen.link

Friends of Shodan

- **Censys** – strong on TLS certificates
- **crt.sh** – certificate transparency, `%.example.com`
- **GitHub search** – leaked keys, `filename:.env`
- **Wayback Machine** – what the site used to say

Rules

Finding is recon. Accessing is intrusion.

Responsible Use

- Document, don’t log in
- Found something serious? Report it (CERT, the organization)
- Only touch systems you are authorized to test

Defense


LOUDER CROWDER
LOUDER CROWDER
ROBOTS.TXT
IS NOT A
SECURITY CONTROL
CHANGE MY MIND
Memegen.link

Stay Out of the Index

- `robots.txt` is a polite request, not a lock
- `noindex` meta tag, Search Console removal
- Real fix: authentication, not obscurity

Watch Your Own Footprint

```
site:yourcompany.com intitle:"index of"
site:yourcompany.com ext:sql
org:"Your Company" vuln:*
```

Quarterly. Fix what you find. Strip version banners.

Remember

- Dorks find documents; Shodan finds devices
- Passive, but very effective
- Finding is fine, accessing is not
- Search for yourself before attackers do

Resources

- exploit-db.com/google-hacking-database
- shodan.io, help.shodan.io
- TryHackMe Google Dorking room

Module 02: Reconnaissance

Search Engines for Reconnaissance

Project Athena